

Clase 211 — Forense móvil

Parte: 9 — Forense digital y respuesta a incidentes · Fuente: NIST SP 800-101 Rev. 1 — Guidelines on Mobile Device Forensics 🕒 Duración estimada: 120 min · Nivel: Avanzado

Objetivo

Comprender los retos particulares de la forense en dispositivos móviles (Android e iOS): niveles de extracción, cifrado, bloqueo, y los artefactos donde vive la evidencia (bases SQLite de apps, mensajes, ubicación, registros de llamadas). Al terminar sabrás planificar una adquisición móvil y analizar sus artefactos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Explicar** los niveles de extracción móvil (manual, lógica, sistema de archivos, física).
2. **Describir** el impacto del cifrado y el bloqueo en la adquisición.
3. **Localizar** artefactos clave en Android e iOS.
4. **Analizar** bases SQLite de apps de mensajería y ubicación.
5. **Usar** ADB y herramientas forenses móviles de forma metódica.

Temas

#	Tema	Por qué importa
1	Retos del móvil	Cifrado, bloqueo, diversidad
2	Niveles de extracción	Qué se puede obtener
3	Android: estructura y /data	Dónde viven las apps
4	iOS: backups y keychain	Modelo cerrado de Apple
5	Bases SQLite de apps	Mensajes, contactos, llamadas
6	Ubicación y actividad	Reconstruir movimientos
7	ADB y modo de arranque	Acceso técnico a Android
8	Aspectos legales y consentimiento	Límites de la extracción

Definiciones y características

- **Extracción lógica:** copia de archivos accesibles vía API/backup. Característica: rápida pero limitada a lo que el SO expone.
- **Extracción de sistema de archivos:** acceso más profundo a la partición de datos. Característica: requiere privilegios (root/jailbreak) o exploits.

- **Extracción física:** imagen bit a bit de la memoria. Característica: máxima, pero difícil por cifrado moderno.
- **FBE (File-Based Encryption):** cifrado por archivo en Android moderno. Característica: complica la extracción física sin credenciales.
- **iOS backup:** respaldo (cifrado o no) vía iTunes/Finder. Característica: fuente forense estándar en iOS.
- **Keychain:** almacén cifrado de credenciales en iOS. Característica: protegido por hardware (Secure Enclave).
- **BFU vs. AFU:** *Before First Unlock* (más cifrado) vs. *After First Unlock* (claves en memoria). Característica: AFU permite más extracción.

Herramientas y preparación

- **Android:** adb (Android Debug Bridge), DB Browser for SQLite, ALEAPP.
- **iOS:** análisis de backups con iLEAPP, libimobiledevice.
- **Comerciales (referencia):** Cellebrite UFED, Magnet AXIOM, Oxygen Forensic (no libres; se mencionan por su rol en la industria).
- **Entorno:** usa un dispositivo o emulador PROPIO. La extracción de un móvil ajeno requiere consentimiento u orden judicial; respétalo siempre.

Laboratorio guiado

Usa un dispositivo Android propio (o un emulador) con datos de prueba que tú generas.

1. Habilita depuración USB en el dispositivo propio y conecta ADB:

```
bash adb devices
```

2. Realiza una extracción lógica por backup:

```
bash adb backup -all -f backup.ab
```

3. Convierte el backup a un tar analizable (con `abe.jar` o `android-backup-extractor`).
4. Extrae info del dispositivo:

```
bash adb shell getprop ro.product.model adb shell dumpsys package com.whatsapp | head
```

5. Analiza una base SQLite de una app de mensajería PROPIA (por ejemplo, tus propios mensajes de prueba):

```
sql SELECT datetime(timestamp/1000,'unixepoch'), sender, body FROM messages ORDER BY timestamp;
```

6. Procesa la extracción con ALEAPP para un informe automatizado (ubicación, apps, notificaciones, uso).
7. Revisa artefactos de ubicación y actividad de apps que ALEAPP consolida.
8. Documenta el método de extracción, el nivel logrado y por qué (bloqueo, cifrado).

Ejercicios

1. Explica las diferencias entre extracción lógica, de FS y física.
2. Describe por qué BFU limita más la extracción que AFU.
3. Realiza un backup ADB de un dispositivo propio y lístalo.
4. Analiza una base SQLite de mensajes propia con SQL.
5. Genera un informe con ALEAPP o iLEAPP.
6. Redacta los requisitos legales para extraer un móvil ajeno.

Reto verificable

En un dispositivo Android propio, genera actividad de prueba (mensajes, ubicaciones simuladas), extrae los datos y reconstruye una línea de tiempo de esa actividad a partir de las bases SQLite y el informe de ALEAPP.

Criterio de aceptación: entregas una timeline con al menos cinco eventos (mensajes, aperturas de app, ubicaciones) fechados, cada uno con la base de datos o artefacto de origen, y describes el nivel de extracción que lograste.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>adb devices</code> no lista el equipo	Depuración USB desactivada o falta autorizar la clave RSA. Acepta el diálogo en el móvil.
<code>adb backup</code> vacío	Apps modernas bloquean backup (<code>allowBackup=false</code>). Necesitas otro método.
Datos cifrados ilegibles	Dispositivo en BFU o FBE. Requiere credenciales o herramientas especializadas.
Timestamps en milisegundos	Divídelos entre 1000 antes de convertir a época Unix.
Alteraste el dispositivo	Encenderlo/usarlo cambia datos. Documenta y usa modo avión/aislamiento (Faraday).

Preguntas frecuentes

? ¿Por qué es tan difícil la forense de iOS? Por su cifrado por hardware (Secure Enclave) y modelo cerrado. Los backups son la vía forense más común.

? ¿Qué es BFU vs AFU? Before/After First Unlock. En AFU las claves de descifrado están en memoria, permitiendo más extracción; en BFU casi todo está cifrado.

? ¿Necesito root para extraer Android? Para extracción profunda (FS/física) normalmente sí, o exploits. La lógica vía backup no lo requiere pero es limitada.

? ¿Puedo extraer un móvil ajeno? Solo con consentimiento del titular u orden judicial. Hacerlo sin autorización es ilegal.

Referencias

- NIST SP 800-101 Rev. 1: <https://csrc.nist.gov/publications/detail/sp/800-101/rev-1/final>
- ALEAPP / iLEAPP: <https://github.com/abrignoni>
- Android Debug Bridge: <https://developer.android.com/tools/adb>
- libimobiledevice: <https://libimobiledevice.org/>

Siguiente clase

Clase 212 - Forense en la nube